Name: Micah Mitchell

ID: 816046428

Course Code and Title: INFO 2605 – Professional Ethics and Law

Date: 30/9/2026

Assignment 1

Name: Micah Mitchell ID: 816046428

Case Overview:

Between April 2023 and September 2023, there were a series of data breaches that targeted DNA sequencing and matching Company, 23 & Me. The attacks targeted 14000 users who reused old passwords, once accessible, the hackers were able to use these accounts to gain profile data from 5.5 million users who were connected to the initially hacked profiles using the 23 & Me DNA relative feature, that allowed users data to be shared with other DNA matches across the platform. The jurisdiction for legal preceding was the United States, where the company is registered and where most customers reside. The data obtained from the leak was offered over online message boards as well as the dark web, sometimes for a price. Furthermore, demographic lists were created from the aggregate data that targeted Chinese and Ashkenazi Jewish individuals. 23 & Me in response to the incident forced all users to change their passwords and set up 2 factor authentication. This case matters because it reinforces that security does not only depend on your actions, but the actions of others using the same platform as you. It is also a study of the consequences of this lack of action, as 23 & Me, less than a year later, filed for bankruptcy.

Ethical Dilemma and Stakeholders:

The Ethical Dilemma is whether 23 & Me has a heightened responsibility for protecting data due to the nature of said data and the way their DNA relative system works, even when the breach was only made possible due to the exploitation of reused, compromised customer passwords, or should the responsibility be shared. The primary stakeholder in this scenario where the customers data has been stolen. The secondary stakeholder is the company, 23 & Me, who have filed for bankruptcy largely due to this incident. The customers now may live in fear, as their genetic information, location, name, and birth data now live on dangerous parts of the internet forever. Their privacy can never truly be restored. On the behalf of the company, they have had to pay large sums of money fixing the issue and lost huge amounts of business, as customers no longer trust them.

On the one hand, the customers who signed up to use 23 & Me were made aware of the risk associated with the technology through terms and conditions, furthermore, the action to opt in to DNA relatives also comes with a whole new level of risk as you are giving the platform permission to share you information with anyone who is a DNA match to you. On the other hand, this is not what users would expect to happen when signing up for this feature. The company, knowing the risk associated with this type of data and the workings of the DNA relative function, should’ve known that one person’s compromised account can lead to many others having their data compromised, a fact that was not made aware to customers.

Ethical Analysis:

The two Ethical Theories I will apply to this scenario are Kantianism and The Social Contract Theory. Kantianism says that there is good will and following it leads to the right course of action or the Ethical Right. From the perspective of the users of 23 & Me, goodwill would be everyone making sure their passwords were strong and up to date, as they understand they would understand the consequences of these actions not being taken. From the perspective of 23 & Me and its practitioners, goodwill would ensure that there is a level of security that would prevent one user account's compromise from leading to all users with a similar genome losing their information as well. This is so, because both decisions would be made with the well-being of others in mind. The other theory is the Social Contract Theory. In this case, the users of 23 & Me would see what happened to them as a violation of a Positive right, the perpetrator being the 23 & Me company, however, 23 & Me would argue that this is a limited right or not a right at all, given the company settled a class-action lawsuit for $30 million (Eddy, 2025).

By Kantianism, 23 & Me would be wrong as they failed to act in goodwill to ensure extra levels of security for their DNA relatives' system, but the customers would also be wrong as they did not consider the impact reusing passwords could have on other users of the system. However, this Theory ignores the fact that neither stakeholders may have even considered this, thus, it could've been a situation where negligence was to blame, and the Onus lies more readily on 23&Me to protect users' data than it does on the customer to protect other user's data. However, according to Social Contract Theory, 23 & Me is not liable because the users' right was limited, and therefore not the fault of the company to uphold. I believe the more reasonable conclusion is that there is some degree of abstraction when trusting companies with this type of data, but by the importance of such data, you must personally ensure that your data is protected. If you are in a situation where your data is protected by a strong password and is still accessed by the public through DNA relatives, you have to acknowledge the fact that you opted in to this data being shared publicly, and there is no guarantee that those viewing it are good actors. 23 & Me is not at fault by Social Contract Theory, as users' rights were limited.

Professional Responsibility:

To Act consistently with Public Interests can means for 23 & Me to implement better internal security, so that a data breach affecting 0.1% or roughly 14000 user accounts (23 & Me Blog Team, 2023), does not lead to 7 million account breaches. The duty falls on developers to identify redundancies in security that can allow unprivileged accounts to have access to a large amount of unsuspecting user's data. This is poor software design and is negligent of use cases of negative actors.

Recommended Response:

The immediate recommended response would be to shut down the website and force everyone to change their passwords, as well as enable 2 Factor Authentication through some token creation service. This action was partially taken by 23 & Me immediately, as they required all users to reset their passwords (Hibbs, 2023). Thus, the users accounts could not have been hacked through brute force methods, as the perpetrator would need the OTP. I believe the next, process-based step should be to ensure that the DNA Relative system is only accessible through using an OTP, each time. Also, allowing for stricter password requirements as it pertains to length, and abstractness. Both reduce the likelihood that someone accesses any of the data for nefarious reasons, as they would need to go through an extra step each time they access it. Finally, as a larger policy focused step, I suggest codifying that all systems storing sensitive data such as this must meet stricter guidelines for how it is shared between people on the platform and ensuring that security meets some 3rd party, government provided standard, thus, removing personal interest from the picture completely. This helps companies with a blueprint to build their security systems on; this also helps them avoid liability if something goes wrong as they can prove they were abiding by the standards codified. It helps customers as it ensures their data is safer, based on a standardized system.

Personal Reflection:

Looking at this case, it becomes apparent to me that, despite abstractions in our understanding and trust given to large corporations, it is very likely that the protection of our data lies in our hands. Furthermore, when in a situation where our data is compromised, we must accept that the documents we sign or agree to, even though we may not read it completely, allow for these companies to absolve themselves of responsibility. This is also morally viable and can only be seen as otherwise if we were to argue that we were acting without free will when engaging with these websites, which is not the truth. It also teaches me that some bad actors act with no rhyme or reason, and with all hostile intent. Furthermore, it shows that your negligence as a customer with regards to securing your information may open the door for those doing the right thing to get hurt as well.

If I were in a scenario such as this, sharing data as personal as this, I would not be opted into the DNA Relatives function of 23 & Me; If I were and my data was leaked, I would ensure that I change not just my account information that was breached, but other accounts sharing the same login information. I would then claim my piece of the settlement payout as it is my right as an affected user. Then, moving forward, I would remove any data 23 & Me had from my account so that, when ownership of the company changes, my data is not used for a cause I did not sign up for.

References:

23andMe Blog Team. (2023, December 5). *Addressing data security concerns – Action plan*. 23andMe Blog. https://www.23andme.org/blog/articles/addressing-data-security-concerns/ 23andMe Blog

23andMe Holding Co. (2023, December 1). *Form 8-K/A: Amendment no. 1* [Current report]. U.S. Securities and Exchange Commission. https://www.sec.gov/Archives/edgar/data/1804591/000119312523287449/d242666d8ka.htm sec.gov

Carballo, R. (2023, December 4). Data breach at 23andMe affects 6.9 million profiles, company says. *The New York Times*. https://www.nytimes.com/2023/12/04/us/23andme-hack-data.html Center for Genetics and Society

Carballo, R., Schmall, E., & Tumin, R. (2024, January 26). 23andMe breach targeted Jewish and Chinese customers, lawsuit says. *The New York Times*. https://www.nytimes.com/2024/01/26/business/23andme-hack-data.html ELSIhub

Eddy, M. (2025, March 25). *23andMe just filed for bankruptcy. You should delete your data now.* Wirecutter. https://www.nytimes.com/wirecutter/reviews/23andme-data-bankrupt/ Oxford Academic

Settlement Agreement, *In re 23andMe Holding Co.*, No. 25-40976-357 (Bankr. E.D. Mo. Aug. 4, 2025). https://www.23andmedatasettlement.com/files/23andMe_Settlement%20Agreement.pdf

Generative AI use declaration Select one:

I used generative AI tools as described below.

Tool and purpose: The tool I used is the ChatGPT to help format my references into APA formation.

How I verified and revised the output: I checked each citation and ensured that the format was correct.

Appendix:

Timeline:

October 1st 2023: 23 & Me became aware that a bad actor accessed roughly 14000 customer accounts

October 10th 2023: 23 & Me required all users to change their passwords

October 20th 2023: 23 & Me temporarily disabled certain features such as DNA relatives to assist with investigation

November 6th 2023: 23 & Me enforced that all users must enroll in 2 factor authentication

June 5th 2024: Federal class-action lawsuit was coordinated and filed against

July 15th 2024: 23 & Me reach agreement to settle the US class action litigation